

This month, in coding

From Elastic and AWS's battle, Copilot's faulty code suggestions to GitLab's latest scanning tool

Mithun Mohandas |
 mithun@digit.in

Amazon's Elasticsearch fork attains General Availability

A couple of months ago, Amazon Web Services had a fallout with Elastic whose ElasticSearch product has been the staple across several AWS services. AWS had rebranded the product as AWS Elasticsearch which made it seem as if ElasticSearch was created by AWS. Elastic relicensed

ElasticSearch and made it so that it was no longer Open Source. AWS went ahead and forked the previous version of ElasticSearch to retain its Open Source status. AWS is calling this new fork OpenSearch and it just attained General Availability status with the release of version 1.0. OpenSearch 1.0 is an Apache 2.0-licensed fork that incorporates ElasticSearch 7.10.2 and Kibana 7.10.2.

Elastic, on the other hand, has begun making client libraries incompatible with OpenSearch. Their Python client now verifies if the connection is with ElasticSearch or a third-party and raises an error for an incorrect response. And that's just the beginning. AWS, in response to this move, has committed to cre-



ating a new set of client libraries that will work with both, OpenSearch as well as with ElasticSearch. It would be interesting to see how things progress from this point.

Copilot's ongoing woes

GitHub's AI programming companion has received mixed reactions since its launch. It was found that Copilot was copying massive chunks of code from projects



GitHub
 Copilot

that were not covered under proper licenses. So GPL licensing was being violated in several instances. Its recent woes have been around faulty code suggestions. Since suggesting code is literally what the service was built for, getting the wrong suggestion or suggestions with known vulnerabilities beats the purpose. And this was recurring when the programming language used was memory-unsafe. One way of tackling the issue would be to switch to a more modern programming language that has baked in security paradigms but that wouldn't be applicable to all users.

GitLab introduces Package Hunter

Speaking of malicious code, GitLab's new Package Hunter tool can scan your dependencies for malicious code. One of the vectors for malicious code to enter a system is by hijacking the dependencies on which projects rely. This way, a huge chunk of projects that calls the dependency directly from the infected source will automatically get infected. Unless, of course, you store the dependencies locally. Package Hunter scans dependencies in a sandboxed environment and looks for unexpected behaviour by monitoring the system calls that the dependency makes. It then alerts the user. Package Hunter is currently supported for NodeJS modules and Ruby Gems.

